

⚡ VAPT — NEURALSH.COM · JUNE 2026

Diagram

4 attack scenarios · 2 confirmed exploited · Real IP: 103.16.62.217

Reconnaissance Vulnerability Critical Exposure Exploitation Impact ⚡ EXPLOITED Confirmed in test

4

CRITICAL FINDINGS

4

HIGH FINDINGS

2

CHAINS EXPLOITED

10.0

MAX CVSS SCORE

01

Full Server Compromise via WHM Root Panel

Exploits N-014 (CVSS 10.0) · cPanel exposed admin panels · Shared hosting lateral movement

CRITICAL PATH

ROOT ACCESS

STARTING POINT

Attacker

Internet-based
No credentials
No prior access

RECONNAISSANCE

DNS & WHOIS Lookup

dig MX neuralsh.com
Reveals real origin IP 103.16.62.217

OSINT

SCANNING

Full Port Scan

nmap 103.16.62.217
20 services found
Ports 2083/2087 open

nmap -sV

CRITICAL EXPOSURE

WHM Panel Exposed

Port 2087 — no IP restriction, no 2FA
Login page public

N-014 · 10.0

EXPLOITATION

Credential Attack

Brute force with large wordlist OR email → /resetpass

N-013 · 9.8

POST-EXPLOITATION

WHM Terminal

WHM → Advanced
→ Terminal
whoami → root

Root Shell

WORST-CASE IMPACT

Complete server ownership — all hosted domains, all databases, all email accounts, all co-tenant data compromised via shared hosting lateral movement

Root RCE

Data Exfiltration

Lateral Movement

02

Unlimited API Abuse via Rate Limit Bypass

X-Forwarded-For spoofing · 100% bypass rate confirmed · 50 tokens farmed in 3 seconds

⚡ CONFIRMED EXPLOITED

100% BYPASS

⚡ This chain was fully executed during the assessment with confirmed results

50/50 tokens · 0 rate limit responses · 3 seconds

STARTING POINT

Attacker

Internet-based
No credentials
No prior access

RECONNAISSANCE

JS Bundle Analysis

Extracts full API route map from /_nuxt/*.js bundle

N-006 · 5.3

VULNERABILITY

Unauth Token Endpoint

GET /web/v1/init/token
Returns HS256 JWT
No auth required

N-007 · 5.3

EXPLOITATION

X-Forwarded-For Bypass

Spoof random IP per request → server trusts header

N-005 · 9.1 ⚡

CONFIRMED RESULT

Token Farm

50/50 valid JWTs collected in 3s
Perpetually renewable

50/50 · 100%

IMPACT

Unlimited API Access

All endpoints accessible at scale
No rate limit ever

CONFIRMED EXPLOITATION RESULT

Rate limiting completely defeated — 50 valid signed JWT tokens collected in 3 seconds. API abuse, credential stuffing, and enumeration attacks can now proceed at unlimited scale.

Confirmed 100%

API Enumeration

Token Farming

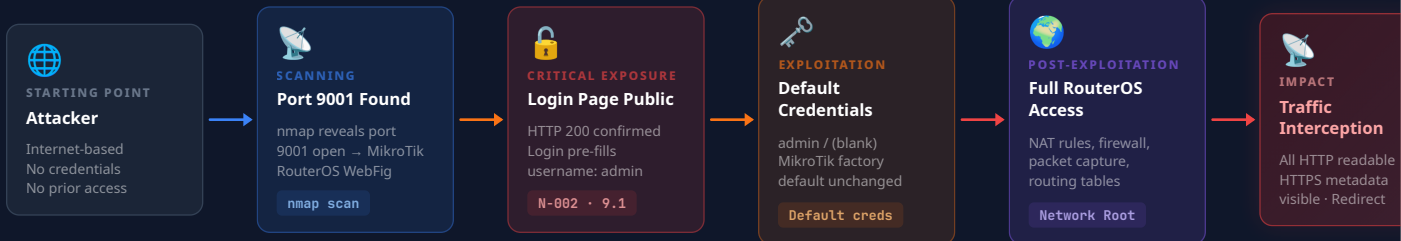
03

Network Infrastructure Takeover via MikroTik Router

Port 9001 publicly exposed · Default credentials admin/(blank) · Full RouterOS access

HIGH LIKELIHOOD

TRAFFIC INTERCEPT



NETWORK-LEVEL IMPACT

- Full control of routing infrastructure — attacker can intercept all traffic, modify NAT rules, extract VPN credentials, create persistent backdoor accounts, and disrupt all hosted services

Network Control

Packet Capture

Persistence

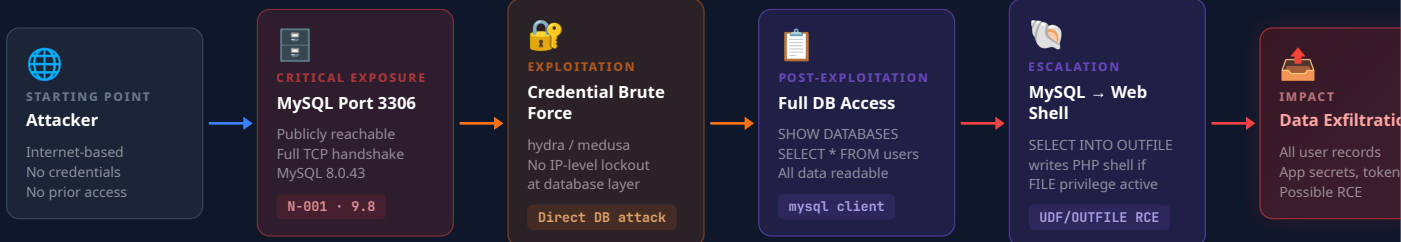
04

Database Exfiltration via Exposed MySQL Port

Port 3306 publicly accessible · Direct brute force against database layer · Potential RCE via MySQL UDF

DATA AT RISK

MEDIUM COMPLEXITY



DATA BREACH SCENARIO

- All application data accessible if credentials obtained — user records, search history, API keys. With FILE privilege, web shell deployment achieves full server code execution without needing WHM access.

Data Breach

Possible RCE

No Lockout

INFRASTRUCTURE ATTACK SURFACE — 103.16.62.217